HPCC4 · TEAM 4 · WINDOWS BOXES

Comp-Day Cheat Sheet

Startup steps in order, then one-liners. Run everything in PowerShell as Administrator.

Quick reference

Box	IP	OS	Folder	Scored
manifest-4	`172.16.4.40`	Server 2019	`manifest-2019`	RDP (jmoney) + MariaDB `3306`
assembly-4	`172.16.4.30`	Server 2022	`assembly-2022`	RDP (jmoney) + Jenkins `8080`

Item	Value
Renamed admin	`Salty_Goose47`
blackbox (logs, backups)	`172.16.4.5` : never block it
blackbox SFTP login	`plinktern` / `H00ves0nTheM00n`

Rules: never delete or disable `jmoney` (RDP only, not admin). Put every new password in NEIGH → Users. No password changes at lunch (12:00–13:30).

Startup steps (each box)

1 Log in as `plinktern` and open PowerShell as Administrator

- No RDP? Use NEIGH → Boxes → Console.
- RDP from Kali (single-quote the password so `!` and `$` survive):

```
xfreerdp /u:plinktern /p:'PASSWORD' /v:172.16.4.40 /cert:ignore
```

Download WinSCP now (see Backups to blackbox). After step 2 the box can't reach the internet.

Trap: the script deletes every local user not on its list. Logged in as anyone other than plinktern or jmoney, it deletes your own account.

2 Pull and run the script for this box

MANIFEST-4

```
cd C:\; curl.exe -fLo s.zip https://github.com/joshjwalter/Pwneigh-scripts-windows/archive/main.zip; tar xf s.zip; powershell -ep bypass -f C:\Pwneigh-scripts-windows-main\manifest-2019\hpcc4-manifest.ps1
```

ASSEMBLY-4

```
cd C:\; curl.exe -fLo s.zip https://github.com/joshjwalter/Pwneigh-scripts-windows/archive/main.zip; tar xf s.zip; powershell -ep bypass -f C:\Pwneigh-scripts-windows-main\assembly-2022\hpcc4-assembly.ps1
```

- It asks for one password for every enabled account (you, jmoney, Salty_Goose47). Blank skips.
- The scored port stays down until the run ends.
- Add `-DryRun` to the end to preview without changing anything.
- In cmd: `cd /d C:\ &` and `&` instead of `;`.

3. **Install 360TS when its window pops up**

   Click through. Outbound internet is already closed by then; the installer works offline.

4. **Read the summary**

   - Red `FAILED` lines.
   - `Password changed`: **update the NEIGH Users tab** for every check on that box.
   - Any yellow suspicious persistence entries.

5. **Sign out and back in**

   Picks up the new policy and fixes Internet Explorer crashing.

6. **Switch the scored service to a virtual account**

   It ends up running as `NT SERVICE\<service name>`: no password, no admin. See Service account switch below.

7. **Check the scoreboard**

8. **Delete the download and the folder**

   `C:\s.zip` and `C:\Pwneigh-scripts-windows-main`. Pull again to re-run.

Service account switch

MariaDB	Jenkins

Box	manifest-4	assembly-4
Downtime	10–30 s	1–2 min
Account	`NT SERVICE\MariaDB`	`NT SERVICE\Jenkins`
Full guide	`SWITCH-MARIADB.md`	`SWITCH-JENKINS.md`

A · OPEN THE SERVICE

Double-click it in `services.msc`. On the **Log On** tab, write down who it runs as now (you need it to roll back). Already Local Service, Network Service or `NT SERVICE\…`? It's low-rights already: skip this section.

- MariaDB: **Path to executable** looks like `"…\bin\mysqld.exe" "--defaults-file=…\data\my.ini" MariaDB`. The `--defaults-file=` part is where `my.ini` is.
- Jenkins: **Path to executable** looks like `"C:\Program Files\Jenkins\jenkins.exe"`. `jenkins.xml` is in the same folder.

B · STOP THE SERVICE, THEN GRANT THESE TO NT SERVICE\<NAME>

Service	Folder (default install)	Permission
MariaDB	`C:\Program Files\MariaDB <ver>`	Read & execute
MariaDB	`C:\Program Files\MariaDB <ver>\data`	Modify
Jenkins	`C:\ProgramData\Jenkins` (home)	Modify
Jenkins	`C:\Program Files\Jenkins`	Modify
Jenkins	Java folder (e.g. `C:\Program Files\Eclipse Adoptium`)	Read & execute

If different:

- MariaDB: `--defaults-file=` points elsewhere? The `datadir=` in that `my.ini` gets Modify, and so does any `log`, `tmpdir` or `secure-file-priv` path outside it.
- Jenkins home: if `JENKINS_HOME` in `jenkins.xml` uses `%LocalAppData%`, `%USERPROFILE%` or `%APPDATA%`, save a copy as `jenkins.xml.bak`, replace it with the real absolute path and grant that folder Modify. **Otherwise Jenkins starts empty.**
- Jenkins Java: the folder `<executable>` points to in `jenkins.xml`.
- Backup job › Configure: mysqldump outside these gets Read & execute; its output folder gets Modify.

How: Folder › Properties › **Security** › Edit › Add › `NT SERVICE\MariaDB` › Check Names › OK › tick the permission › OK.

C · SWITCH AND START

Log On tab › This account: `NT SERVICE\<name>` › clear both password boxes › OK › **Start**.

D · CHECK IT WORKS

- MariaDB: status Running, Log On As `NT SERVICE\MariaDB`. Won't start? The newest `*.err` in datadir names the path it couldn't open: grant Modify, Start again.
- Jenkins: wait ~30 s, log in at `http://localhost:8080` as the scored user, run the backup job (**Build Now**). Setup wizard or missing jobs = wrong home. Won't start? The newest `*.log` in the install folder names the path.

E · ROLL BACK (STILL DOWN AFTER A FEW MINUTES)

Log On tab › **Local System account** › OK › Start. Jenkins: put `jenkins.xml.bak` back first if you edited it. If it ran as a real user before, put that account back with its new password.

Backups to blackbox

1 Download WinSCP before step 2

From `https://winscp.net/eng/download.php`. Install it and run it as administrator. Missed it? Open 443 out, download, close it again:

```
New-NetFirewallRule -Name tmp443 -DisplayName tmp443 -Direction Outbound -
Protocol TCP -RemotePort 443 -Action Allow
Remove-NetFirewallRule -Name tmp443
```

2 Connect

New Session › SFTP › host `172.16.4.5`, port 22, user `plinktern`. If it can't connect, add the rule (the script should already allow it):

```
New-NetFirewallRule -Name ssh-blackbox -DisplayName ssh-blackbox -Direction
Outbound -Protocol TCP -RemoteAddress 172.16.4.5 -RemotePort 22 -Action Allow
```

3 Drag and drop

Backups go from the left (this box) to the right (blackbox).

Box	What to copy
manifest-4	Dump first (copying the live `data` folder gives a broken copy), then copy `C:\Users\Public\db.sql` and `C:\HPCC4`, then delete the local `db.sql`.
assembly-4	`C:\ProgramData\Jenkins\.jenkins` (too big? at least `jobs\`, `users\`, `secrets\`, `config.xml`, `credentials.xml`) and `C:\HPCC4`.

```
& "C:\Program Files\MariaDB <ver>\bin\mysqldump.exe" -u root -p --all-databases --
```

```
result-file=C:\Users\Public\db.sql
```

One-liners

USERS

List users	`Get-LocalUser | ft Name,Enabled,LastLogon,PasswordLastSet`
Local admins	`Get-LocalGroupMember Administrators`
Who is logged in	`quser`
Kick a session	`logoff <ID>`
Disable a user	`Disable-LocalUser <name>`
Reset one password	`net user <name> *`
Remove from admins	`Remove-LocalGroupMember Administrators <name>`
Fix jmoney	`Enable-LocalUser jmoney; Add-LocalGroupMember -SID S-1-5-32-555 -Member jmoney; Remove-LocalGroupMember -SID S-1-5-32-544 -Member jmoney`

NETWORK

Listening ports	`Get-NetTCPConnection -State Listen | sort LocalPort | select LocalPort,OwningProcess,@{n='Path';e={(Get-Process -Id $_.OwningProcess -EA 0).Path} }`
Who's connected	`Get-NetTCPConnection -State Established | select RemoteAddress,RemotePort,@{n='Proc';e={(Get-Process -Id $_.OwningProcess -EA 0).Name} }`
Our firewall rules	`Get-NetFirewallRule -Name 'HPCC4-*' | ft Name,Direction,Action,Enabled`
Block an IP	`New-NetFirewallRule -Name HPCC4-BlockIP-1 -DisplayName HPCC4-BlockIP-1 -Direction Inbound -RemoteAddress <IP> -Action Block`

HUNT

Odd services	`Get-CimInstance Win32_Service | ? { $_.PathName -notmatch 'Windows\\(System32|SysWOW64)' } | ft Name,StartName,PathName -Wrap`
Odd scheduled tasks	`Get-ScheduledTask | ? TaskPath -notlike '\Microsoft\*' | ft TaskPath,TaskName,State`
Run keys	`Get-ItemProperty`

	`HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run*, HKCU:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run* -EA 0`
Failed logons (1 h)	`Get-WinEvent -FilterHashtable @{LogName='Security';Id=4625;StartTime=(Get-Date).AddHours(-1)} | ft TimeCreated,Message -Wrap`
New users, groups, log wipes	`Get-WinEvent -FilterHashtable @{LogName='Security';Id=4720,4732,1102} -MaxEvents 30 | ft TimeCreated,Id,Message -Wrap`
New services	`Get-WinEvent -FilterHashtable @{LogName='System';Id=7045} -MaxEvents 20 | ft TimeCreated,Message -Wrap`
RemoteApp backdoor	`reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Terminal Server\TSAppAllowList" /v fDisabledAllowList`

RemoteApp value should be missing or 0. If it's 1, set it back with `reg add` (same key, `/v fDisabledAllowList /t REG_DWORD /d 0 /f`). Also read `C:\HPCC4\persistence.txt`.

CONTAIN

Kill a process	`Stop-Process -Id <PID> -Force`
Kill a service	`Stop-Service <NAME> -Force; Set-Service <NAME> -StartupType Disabled`
Kill a task	`Disable-ScheduledTask -TaskPath '\' -TaskName '<NAME>'`

SCORED SERVICES

Status / restart	`Get-Service MariaDB` · `Restart-Service Jenkins`
Runs as who	`Get-CimInstance Win32_Service | ? Name -match 'maria|mysql|jenkins' | ft Name,State,StartName`
Jenkins up? (200)	`(iwr http://localhost:8080/login -UseBasicParsing).StatusCode`
Undo account switch	`Invoke-CimMethod -InputObject (Get-CimInstance Win32_Service -Filter "Name='MariaDB'") -MethodName Change -Arguments @{StartName='LocalSystem';StartPassword=''}; Start-Service MariaDB`

For Jenkins, swap `Jenkins` in for `MariaDB` in the undo line.

ROLLBACK

Firewall	`netsh advfirewall import C:\HPCC4\firewall-before.wfw`
Security policy	`secedit /configure /db C:\HPCC4\r.sdb /cfg C:\HPCC4\gpo-before\secpol-before.inf`

Audit policy	`auditpol /restore /file:C:\HPCC4\gpo-before\audit-before.csv`
GPO	Pull the scripts again for `LGPO.exe`, then `LGPO.exe /g <GUID folder in C:\HPCC4\gpo-before>` and `gpupdate /force`
Service account	Service account switch, step E

CLEAR HISTORY

PowerShell	`Remove-Item (Get-PSReadLineOption).HistorySavePath -EA 0`
Bash (Kali)	`unset HISTFILE; history -c; history -w`

Watch out

- **After the run, outbound only reaches** `172.16.4.5` (and `172.16.4.40:3306` from assembly). Downloads won't work.
- **Jenkins' outbound needs** (plugin updates, for example) are unchecked, so it may break on that.
- **The hosts file is locked.** Run the script with `-Unlock` to edit it.
- **Tools are in** `C:\Tools`, on the PATH in new shells: Autoruns64, procexp64, Procmon64, tcpview64, Sysmon64 (not installed).
- **Run outputs are in** `C:\HPCC4`**:** `persistence.txt`, `firewall-before.wfw`, `gpo-before\`, `backup\`.
- **RDP now requires NLA**, so clients must support it.
- **360TS has never been tested on Server.**

HPCC4 · TEAM 4 · JENKINS → BLACKBOX

Jenkins SSH Agent Cheat Sheet

Run Jenkins builds on blackbox through an SSH agent. Blackbox commands first, then the Jenkins settings.

Quick reference

Item	Value
Agent host	blackbox, `198.18.1.249` (check it on the day)
SSH login	`ubuntu`
Remote root directory	`/home/ubuntu/jenkins`
Label	`blackbox`
Java path	`/usr/bin/java` (confirm with `which java`)

> **Rules:** blackbox is out of Red Team's scope, so make sure the rules allow building on it.

Steps

1 Install Java on blackbox

```
sudo apt-get update && sudo apt-get install -y openjdk-21-jre-headless
java -version
which java          # usually /usr/bin/java; you need this in step 2
```

Don't make the agent folder yourself (especially not with `sudo`). Jenkins makes it.

2 Add the node in Jenkins

New Node › Permanent Agent, then set:

- Remote root directory: `/home/ubuntu/jenkins`
- Labels: `blackbox`
- Launch via SSH: host = blackbox IP, credentials = `ubuntu`
- Advanced › JavaPath: `/usr/bin/java`

3 Save, then Launch

The log should end with `Agent successfully connected and online`.

4 **Point a job at it**

Job › Configure › **Restrict where this project can be run** › `blackbox`.

One-liners

Java installed?	`java -version`
Where is Java	`which java`
Fix folder owner	`sudo chown -R ubuntu:ubuntu /home/ubuntu/jenkins`
Jenkins up? (200, on assembly)	`(iwr http://localhost:8080/login -UseBasicParsing).StatusCode`

Watch out

- **`Could not copy remoting.jar` … `Permission denied`:** `ubuntu` can't write to the root directory. Use `/home/ubuntu/jenkins`, not the default `/home/jenkins`. Still fails? The folder exists and belongs to root: run the *Fix folder owner* line.
- **Log shows the old path:** you didn't click Save.
- **`java: command not found`:** do step 1, and set JavaPath.
- **Switching the Jenkins Windows service to a virtual account** is a separate job: see Sheet 01, Service account switch, or `SWITCH-JENKINS.md`.

HPCC4 · TEAM 4 · WINDOWS SERVER SNAPSHOTS

Shadow Copies Cheat Sheet

Snapshot C:, zip the folders you need out of the snapshot, pull them off over SCP, and restore from the zip. Run commands in an elevated prompt.

Quick reference

Item	Value
What a snapshot covers	A whole volume (you can't pick single files)
Snapshot link folder	`C:\ShadowCopy`
Backup folder	`C:\Backups`
Files per backed-up folder	`<folder>.zip` + `<folder>_acl.txt`
SCP path	`/C:/Backups/`

Rules: never use **Revert** on C:. It rolls back the whole volume, OS included (Windows normally blocks it on the system drive anyway).

Steps

1 Make sure VSS is running

```
sc config vss start= demand
net start vss
```

VSS normally starts by itself. The `sc config` line matters only if someone disabled the service; without it, `net start vss` fails.

2 Take the snapshot

- **GUI:** Disk Management › right-click **C:** › Properties › **Shadow Copies** tab › select **C:** › **Create Now**. Keeping the storage area on C: is fine when it's the only volume.
- **Command line:**

```
vssadmin create shadow /for=C:
vssadmin list shadows
```

3 Link the snapshot to a folder

Take the `HarddiskVolumeShadowCopyN` name from `vssadmin list shadows`, then:

```
cmd /c mklink /d C:\ShadowCopy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\
```

Change the `1` to your snapshot's number and keep the trailing backslash. `cmd /c` is needed in PowerShell because `mklink` exists only in Command Prompt. Check it with `dir C:\ShadowCopy`.

4 Zip the files into C:\Backups

For each folder, zip it from the snapshot and save its permissions:

```
mkdir C:\Backups
tar -a -cf C:\Backups\wwwroot.zip -C C:\ShadowCopy\inetpub wwwroot
icacls C:\ShadowCopy\inetpub\wwwroot /save C:\Backups\wwwroot_acl.txt /T /C
```

Replace `inetpub` and `wwwroot` with the parent folder and folder you're backing up. tar says access denied? Copy the folder out first with `robocopy C:\ShadowCopy\inetpub\wwwroot C:\Staging\wwwroot /E /B`, then zip from `C:\Staging`.

5 Download with the SCP client

Browse to `/C:/Backups/` and download the `.zip` and `_acl.txt` for each folder.

6 Restore from the zip

A shadow copy can't be imported back onto the server, but the zip can.

1. Upload the `.zip` and `_acl.txt` to `/C:/Backups/` in the SCP client.
2. If a service has the files open, stop it first (IIS: `iisreset /stop`).
3. Unzip over the live folder:

```
tar -xf C:\Backups\wwwroot.zip -C C:\inetpub
```

4. Restore the permissions, against the **parent** folder (the saved paths are relative to it):

```
icacls C:\inetpub /restore C:\Backups\wwwroot_acl.txt
```

5. Start the service again (`iisreset /start`).

> **Remove planted files too:** unzipping overwrites but doesn't delete extras (such as a webshell). Unzip to `C:\Restore` instead, then `robocopy C:\Restore\wwwroot C:\inetpub\wwwroot /MIR`.

One-liners

Start VSS	`sc config vss start= demand & net start vss`
Take a snapshot	`vssadmin create shadow /for=C:`
List snapshots	`vssadmin list shadows`
Link a snapshot	`cmd /c mklink /d C:\ShadowCopy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\`
Check the link	`dir C:\ShadowCopy`
Zip a folder	`tar -a -cf C:\Backups\<folder>.zip -C C:\ShadowCopy\<parent> <folder>`
Save permissions	`icacls C:\ShadowCopy\<parent>\<folder> /save C:\Backups\<folder>_acl.txt /T /C`
Copy out (access denied)	`robocopy C:\ShadowCopy\<parent>\<folder> C:\Staging\<folder> /E /B`
Unzip over live	`tar -xf C:\Backups\<folder>.zip -C C:\<parent>`
Restore permissions	`icacls C:\<parent> /restore C:\Backups\<folder>_acl.txt`
Mirror restore (deletes extras)	`robocopy C:\Restore\<folder> C:\<parent>\<folder> /MIR`
Stop / start IIS	`iisreset /stop` · `iisreset /start`
Remove the link only	`rmdir C:\ShadowCopy`
Delete one snapshot	`vssadmin delete shadows /shadow={ID}`

Watch out

- **Pull important files off the box.** Any admin can wipe every snapshot with `vssadmin delete shadows /all`.
- `/MIR` **deletes.** Check the destination path before you run it.
- **Permissions carry over.** The SCP login needs rights to the files in the snapshot; an admin account is easiest.
- **Don't browse** `C:\System Volume Information`**.** It holds the raw snapshot data, which you can't read directly.

HPCC4 · TEAM 4 · MALWARE HUNTING

Sysinternals Cheat Sheet

Run on every Windows box, in order. Tools are in `C:\Tools` after the script runs (or `\\live.sysinternals.com\tools`); run them as administrator.

Quick reference

You see	Open	Look for
Odd process	Process Explorer	Purple row, no company name, no signature, runs from the user profile or Windows folder
Pop-up you can't place	Process Explorer	Drag the crosshair onto the window to find its owner
Process comes back after you kill it	Process Explorer	Suspend all copies instead of killing, then clean
Suspicious process, unknown purpose	Process Explorer	Strings tab › Memory for URLs and commands; Ctrl+D for unsigned DLLs
Malware returns after reboot	Autoruns	Red or unsigned entries, plus `RunOnce` and Winlogon shell
Unexpected outbound traffic	Process Monitor	Filter out file and registry events, exclude legit traffic, check remote IPs
Unsure what a process did	Process Monitor	Category is Write; double-click an event for the parent and command line
Hidden or renamed executables	Sigcheck	`-e` catches executables with a fake extension
Malware hiding in a legit process	ListDLLs	`-u` lists unsigned DLLs loaded in any process
Locked-down screen (ransomware)	Safe Mode with Command Prompt	Plain safe mode and safe mode with networking still run the shell autostarts

Rules: check what you may disconnect or block first. Don't kill a scored service by mistake: confirm the process path and signature before you stop anything.

Steps

FIRST 10 MINUTES

1. **Process Explorer**

   Options › Verify Image Signatures, add the Verified Signer column, sort it. Note anything unsigned.

2. **Look for purple rows**

   Packed or encrypted, and processes with no description or company name.

3. **Autoruns**

   Turn on Hide Microsoft Entries and Verify Code Signatures. Note every red or unsigned entry.

4. **Sigcheck**

   Sweep `C:\Windows` and `C:\Users` (one-liners below).

5. **Process Monitor**

   Start a capture filtered to Category is Write, so you have a record of what changes.

6. **Write it down**

   The box, process, file path and time, for the incident report.

CLEAN-UP ROUTINE

1. **Suspend**

   In Process Explorer, right-click › Suspend. Don't kill it; copies may revive each other.

2. **Uncheck**

   Its entries in Autoruns. Uncheck rather than delete, so you can undo.

3. **Delete the file**

4. **Reboot and recheck**

   Repeat from Process Explorer if the symptom comes back.

One-liners

Add `-accepteula` the first time you run each tool, or it stops on a license dialog.

Unsigned executables, System32	`sigcheck -accepteula -e -u -s C:\Windows\System32`
Unsigned executables, user profiles	`sigcheck -e -u -s C:\Users`

Unsigned DLLs in running processes	`listdlls -accepteula -u`
Non-Microsoft autostarts to CSV	`autorunsc -accepteula -a * -s -m -c > autoruns.csv`
Start a quiet Procmon capture	`procmon /AcceptEula /Quiet /Minimized /BackingFile C:\logs\cap.pml`
Stop that capture	`procmon /Terminate`
Strings in a suspicious file	`strings -accepteula file.exe`
Who owns a domain	`whois -accepteula example.com`

In PowerShell, quote the wildcard: `autorunsc -a '*'`.

Watch out

- **Cutting a box off the network can cost scored services.** A firewall rule for just the bad address is usually safer.
- **Packed files:** `strings` on disk is garbage. Use Process Explorer's Memory view on the running process.
- **Plain Safe Mode misses things.** Use Safe Mode with Command Prompt to skip shell autostarts.
- **Autoruns can't see shutdown-only persistence.** If malware returns after a reboot with nothing in Autoruns, run a Process Monitor boot log.
- **Log everything** (box, file, time, action) so the incident report writes itself.